CSA6303- Threat Intelligence and Network Security

AT1: Application-Based Questions

Topics: Network Security Fundamentals | Security Goals (CIA Triad) | Types of Network Threats | Introduction to Threat Intelligence Types of Threat Intelligence (Strategic, Tactical, perational) — Threat Intelligence Lifecycle — Applications in IT Industry

CO1: Interpret security principles, network threats, and the role of threat intelligence in cybersecurity.

Dr.V.Parthipan **Total: 50**

Student Name :T. Bhanu Pavan Varma **Register number: 192425380**

Code of Conduct:

*I **T. Bhanu Pavan Varma(192425380)** (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student

AT1: Application-Based Questions

Q1.CIA Triad — Scenario Identification (5 marks)
An e-commerce site stays fully online during an incident, but customers notice product prices have been silently changed by an attacker who gained database write access. No downtime occurred. Which CIA Triad principle(s) are violated? Justify your answer

Q1. CIA Triad — Scenario Identification

Violated principle: Integrity.

Justification: The attacker gained database write access and silently changed product prices without authorization. This violates Integrity, which ensures that data remains accurate, complete, and unmodified by unauthorized users.

- Confidentiality: Not necessarily violated because no unauthorized data disclosure is mentioned.
- Integrity: Violated because product prices were modified.
- Availability: Not violated because the website remains fully operational.

Conclusion: The primary violation is Integrity.

Q2. Risk Quantification — Annualized Loss Expectancy (10 marks)
A company's customer database is valued at $50,000. A breach would destroy/corrupt 40% of its value (Exposure Factor). Historical data shows this type of breach occurs about twice a year (Annualized Rate of Occurrence = 2). Calculate the Single Loss Expectancy (SLE) and the Annualized Loss Expectancy (ALE). Show all formulas used.

Q2. Risk Quantification — Annualized Loss Expectancy

Given:

- Asset Value (AV) = $50,000
- Exposure Factor (EF) = 40% = 0.40
- Annualized Rate of Occurrence (ARO) = 2

Step 1: Calculate Single Loss Expectancy (SLE)

Formula:

$$ SLE = AV \times EF $$
Substituting the values:

$$ SLE = 50,000 \times 0.40 $$
$$ \boxed{SLE = \$20,000} $$

Step 2: Calculate Annualized Loss Expectancy (ALE)

Formula:

$$ ALE = SLE \times ARO $$
Substituting the values:

$$ ALE = 20,000 \times 2 $$
$$ \boxed{ALE = \$40,000} $$

Final Answer:

- Single Loss Expectancy (SLE) = $20,000

- Annualized Loss Expectancy (ALE) = $40,000 per year

Q3. Brute-Force Attack Time Estimation (10 marks)
An 8-character password uses a 62-character set (a-z, A-Z, 0-9). An attacker's cracking rig tests 1 billion passwords per second. Calculate the size of the keyspace and the worst-case time required to exhaust it. Express your answer in hours.

Q3. Brute-Force Attack Time Estimation

Given:

- Password length = 8 characters

- Character set size = 62

- Cracking speed = 10^9 passwords per second

Step 1: Calculate the keyspace

Formula:

$$ K = C^L $$
Where C is the character set size and L is the password length.

$$ K = 62^8 $$
$$ \boxed{K = 218,340,105,584,896} $$
Step 2: Calculate worst-case time in seconds

Formula:

$$ T = \frac{\text{Keyspace}}{\text{Cracking speed}} $$
$$ T = \frac{218,340,105,584,896}{1,000,000,000} $$
$$ T = 218,340.1056 \text{ seconds} $$
Step 3: Convert seconds into hours

Since 1 hour = 3,600 seconds:

$$ T_{\text{hours}} = \frac{218,340.1056}{3,600} $$
$$ \boxed{T \approx 60.65 \text{ hours}} $$

Final Answer: The keyspace contains approximately 2.1834×10^{14} possible passwords, and the worst-case exhaustive search time is 60.65 hours, assuming a constant cracking rate and no additional delays.

Q4. Risk Prioritization Matrix (10 marks)
Given five threats rated on Likelihood (1-5) and Impact (1-5), compute the Risk Score (Likelihood x Impact) for each and rank them in order of patching/budget priority:
(a) Ransomware — L4, I5;
(b) Phishing — L5, I3;
(c) Insider data theft — L2, I5;
(d) DDoS — L3, I3;
(e) Unpatched server exploit — L4, I4.

Q4. Risk Prioritization Matrix (10 Marks)

Formula:

$$ \text{Risk Score} = \text{Likelihood} \times \text{Impact} $$

Threat	Likelihood (L)	Impact (I)	Risk Score	Priority
(a) Ransomware	4	5	$4 \times 5 = 20$	1
(b) Phishing	5	3	$5 \times 3 = 15$	3
(c) Insider data theft	2	5	$2 \times 5 = 10$	5
(d) DDoS	3	3	$3 \times 3 = 9$	4
(e) Unpatched server exploit	4	4	$4 \times 4 = 16$	2

Ranking in descending order of risk:

1. Ransomware — 20: Highest priority because it has a high likelihood and very high impact.
2. Unpatched server exploit — 16: High priority because attackers may exploit known vulnerabilities.
3. Phishing — 15: High likelihood makes it an important risk to address.
4. Insider data theft — 10: Lower likelihood, but potentially severe impact.
5. DDoS — 9: Lowest score among the given threats.

Conclusion: Ransomware should receive the highest initial priority, followed by the unpatched server exploit. Actual patching decisions should also consider active exploitation and vulnerability severity.

Q5. Passive vs. Active Threat Classification (5 marks)
Classify each of the following as a passive or active threat, and state which CIA principle it primarily threatens:
(a) An attacker silently sniffing unencrypted traffic on a public Wi-Fi network.
(b) An attacker performing ARP spoofing to redirect traffic.
(c) A nation-state actor performing long-term network reconnaissance without altering anything.

Q5. Passive vs. Active Threat Classification (5 Marks)

Scenario	Classification	Primary CIA Principle	Justification
(a) Sniffing unencrypted public Wi-Fi traffic	Passive	Confidentiality	The attacker observes communications without modifying them.
(b) ARP spoofing to redirect traffic	Active	Integrity	The attacker manipulates network address mappings and traffic paths.
(c) Long-term nation-state reconnaissance without alteration	Passive	Confidentiality	The attacker gathers information without changing network data or operations.

Key distinction:

- Passive threats involve observing or collecting information without modifying system resources or communications.
- Active threats involve modifying, injecting, disrupting, or interfering with system operations.

Note: ARP spoofing can also lead to confidentiality breaches if it enables traffic interception.

Q6. Threat Intelligence Lifecycle sequencing (10 marks)
A SOC analyst receives an executive request: "Are we at risk from the ransomware group currently targeting our industry?" Arrange the following into the correct order of the Threat Intelligence Lifecycle, and name each phase:

(i) Analysts correlate collected IOCs with internal logs.
(ii) A report is sent to the CISO.
(iii) The request itself is logged as a requirement.
(iv) OSINT and threat feeds are pulled for the group's known TTPs.
(v) The CISO's follow-up questions shape the next collection cycle.

Q6. Threat Intelligence Lifecycle Sequencing (10 Marks)

The correct order is:

Order	Given Step	Lifecycle Phase	Explanation
1	3	Planning and Direction	The executive request is recorded and intelligence requirements are defined.
2	4	Collection	OSINT sources and threat intelligence feeds are gathered to learn the group's TTPs.
3	1	Processing and Analysis	Analysts correlate collected indicators of compromise (IOCs) with internal logs to assess exposure.
4	2	Dissemination	The findings and recommendations are reported to the CISO.
5	5	Feedback	The CISO's follow-up questions refine intelligence requirements for the next cycle.

Conclusion: The Threat Intelligence Lifecycle is a continuous process. Feedback from decision-makers helps refine requirements and begins the next intelligence cycle.